Порядок реагирования на инциденты информационной безопасности

Документ: ПБ-05-2025
Редакция: 2
Утверждено: приказ № 119 от 12.02.2025
Владелец документа: департамент информационной безопасности
Класс: Внутренний

1. Что считается инцидентом

Инцидентом информационной безопасности считается любое событие, которое привело или могло привести к нарушению конфиденциальности, целостности или доступности информации компании. В частности:

- получение фишингового письма или сообщения;
- утрата или кража ноутбука, телефона, пропуска, токена;
- обнаружение вредоносного программного обеспечения;
- несанкционированный доступ к учётной записи, в том числе подозрение на него;
- случайная отправка документов класса CONF или SECRET внешнему получателю;
- обнаружение корпоративных данных в публичном доступе.

2. Как сообщить об инциденте

Работник обязан сообщить об инциденте в течение 30 минут с момента обнаружения, любым из каналов:

Канал	Реквизиты	Доступность
Телефон горячей линии ИБ	внутренний 7777	круглосуточно
Электронная почта	soc@polaris-tech.ru	круглосуточно
Телеграм-бот	@polaris_soc_bot	круглосуточно
ServiceDesk	категория «Инцидент ИБ»	рабочие часы

Сообщать об инциденте следует даже при наличии сомнений в его реальности. Ложное срабатывание не является нарушением и не влечёт последствий для работника.

3. Классификация и сроки реакции

Уровень	Описание	Время реакции SOC
P1	Критический: активная атака, шифровальщик, утечка SECRET	15 минут
P2	Высокий: компрометация учётной записи, утечка CONF	1 час
P3	Средний: вредоносное ПО на одном устройстве, фишинг с переходом по ссылке	4 часа
P4	Низкий: фишинг без перехода, единичные сканирования	1 рабочий день

4. Действия работника до прибытия специалиста

- Не удалять подозрительные письма и файлы: они нужны для разбора. Переслать письмо на soc@polaris-tech.ru как вложение.
- При подозрении на компрометацию устройства — отключить его от сети (вынуть кабель, отключить Wi-Fi), но не выключать питание.
- Не пытаться самостоятельно связаться с атакующим, отвечать на письма вымогателей, переходить по ссылкам «для проверки».
- Не предупреждать коллег по открытым каналам до согласования с SOC: это может ускорить действия атакующего.
- Зафиксировать время обнаружения и свои действия, передать записи специалисту SOC.

5. Утечка персональных данных

При подтверждённой утечке персональных данных департамент ИБ совместно с юридическим департаментом направляет уведомление в Роскомнадзор в течение 24 часов с момента выявления инцидента, и повторное уведомление с результатами внутреннего расследования — в течение 72 часов. Взаимодействие с регулятором и субъектами персональных данных осуществляет исключительно юридический департамент.

6. Разбор инцидента

По каждому инциденту уровня P1 и P2 в течение 10 рабочих дней после закрытия проводится разбор без поиска виноватых (blameless postmortem) с письменным отчётом и перечнем мер. Отчёт хранится 3 года.